Mục lục

BUỔI 3: ADMIN — QUẢN LÝ DANH MỤC, SẢN PHẨM VÀ ẢNH SẢN PHẨM 2

1. Mục tiêu buổi học 2
2. Kiến thức trọng tâm 2
3. Chuẩn bị 2
4. Các bước xây dựng mã nguồn 3
   - Bước 1: Bảo mật thư mục `uploads` 3
   - Bước 2: Viết lớp `ImageService` — kiểm tra và xử lý ảnh 3
   - Bước 3: Viết Model `Category` 6
   - Bước 4: Viết Model `Product` 7
   - Bước 5: Viết Model `ProductImage` — toàn bộ nghiệp vụ ảnh sản phẩm 8
   - Bước 6: Viết `AdminCategoryController` và view 12
   - Bước 7: Viết `AdminProductController` — CRUD thông tin sản phẩm 16
   - Bước 8: Viết `AdminProductImageController` — xử lý thao tác ảnh 20
   - Bước 9: Hoàn thiện view `admin/product/form.php` — thông tin + khu vực ảnh 23
5. Chạy thử và kiểm tra 27
   - 5.1. Bảng kiểm thử tải ảnh (tối thiểu 8 ca) 28
6. Checklist nghiệm thu cuối buổi 28
7. Bài tập mở rộng (tự làm thêm) 29
8. Nộp bài: đẩy mã nguồn lên GitHub 29

BUỔI 3: ADMIN - QUẢN LÝ DANH MỤC, SẢN PHẨM VÀ ẢNH SẢN PHẨM

Học phần thực hành: Website thương mại điện tử cơ bản (PHP thuần - MVC - MySQL)

Công nghệ sử dụng: PHP 8+, MySQL (PDO), Bootstrap 5 (CDN), Visual Studio Code

> Buổi quan trọng nhất về mặt kỹ thuật của học phần: xây dựng trọn vẹn vòng đời của một ảnh sản phẩm - tải lên an toàn, xử lý bằng GD, lưu trữ, hiển thị, sắp xếp, và xoá - sao cho CSDL và tệp trên đĩa **luôn luôn nhất quán**.

1. Mục tiêu buổi học

- Hoàn thiện CRUD danh mục và sản phẩm có ràng buộc dữ liệu (không xoá danh mục còn sản phẩm, không trùng SKU…).
- Xây dựng `ImageService`: kiểm tra tệp ảnh tải lên một cách an toàn (không tin phần mở rộng hay `Content-Type` trình duyệt gửi lên) và xử lý lại ảnh bằng thư viện GD.
- Xây dựng toàn bộ nghiệp vụ ảnh sản phẩm trong Model `ProductImage`: luôn đúng **một** ảnh đại diện, sắp xếp thứ tự, xoá ảnh đúng trình tự (xoá bản ghi trước, xoá tệp sau), và chặn thao tác trái quyền giữa các sản phẩm.
- Viết đủ bảng kiểm thử tải ảnh với tối thiểu 8 ca kiểm thử.

2. Kiến thức trọng tâm

Chủ đề	Nội dung
Upload nhiều tệp	`<input type="file" name="images[]" multiple>`, cấu trúc mảng `$_FILES['images']`
Kiểm tra tệp an toàn	Mã lỗi `$_FILES[...]['error']`, đuôi tệp, `finfo` (loại thật), `getimagesize()`
GD	`imagecreatefromstring`, `imagecreatetruecolor`, `imagecopyresampled`, `imagejpeg`
Transaction đơn giản	Đảm bảo không bao giờ có 0 hoặc 2 ảnh đại diện cùng lúc
Toàn vẹn dữ liệu	Thứ tự xoá: bản ghi CSDL trước, tệp vật lý sau; ghi log nếu xoá tệp thất bại
Chống thao tác trái quyền	Mọi câu lệnh SQL trên `product_images` đều lọc thêm theo `product_id`

3. Chuẩn bị

- Khởi động Apache, MySQL.
- Đảm bảo extension gd và `fileinfo` đã bật (đã kiểm tra ở Buổi 1).
- Dự án tiếp tục trực tiếp trên mã nguồn Buổi 1 + Buổi 2.

4. Các bước xây dựng mã nguồn

Bước 1: Bảo mật thư mục `uploads`

Trước khi xử lý bất kỳ tệp tải lên nào, phải đảm bảo **thư mục chứa tệp người dùng tải lên không bao giờ được phép thực thi mã PHP**, và không bị liệt kê nội dung công khai.

Tệp: `public/uploads/.htaccess`

```
# public/uploads/.htaccess
# Khong cho thuc thi bat ky file PHP nao trong thu muc upload
# va khong cho liet ke noi dung thu muc

<FilesMatch "\.(php|phtml|php\d)$">
    Require all denied
</FilesMatch>

Options -Indexes
```

> Đây là nguyên tắc sống còn: nếu kẻ tấn công lách được kiểm tra phía ứng dụng để tải lên một tệp `.php` trá hình, cấu hình này đảm bảo Apache **từ chối thực thi** tệp đó dù nó có nằm trong `uploads/` đi nữa.

Bước 2: Viết lớp `ImageService` - kiểm tra và xử lý ảnh

Tệp: `app/services/ImageService.php`

```
<?php
// app/services/ImageService.php
// Kiem tra tep anh tai len an toan va xu ly lai bang GD truoc khi luu.
// Day la noi DUY NHAT trong he thong chua logic xu ly anh bang GD.

class ImageService
{
    /**
     * Kiem tra MOT tep tai len theo dung quy tac o config.php.
     * Tra ve mang rong neu hop le, hoac mang cac thong diep loi.
     */
    public static function validate(array $file): array
    {
        $errors = [];

        $errorCode = $file['error'] ?? UPLOAD_ERR_NO_FILE;
        if ($errorCode !== UPLOAD_ERR_OK) {
            $errors[] = self::uploadErrorMessage($errorCode);
            return $errors; // loi upload co ban thi khong kiem tra tiep
noi dung
        }

        // 1) Kiem tra phan mo rong
        $ext = strtolower(pathinfo($file['name'], PATHINFO_EXTENSION));
        if (!in_array($ext, UPLOAD_ALLOWED_EXT, true)) {
            $errors[] = 'Định dạng tệp không được hỗ trợ (chỉ nhận ' .
```

```
implode(', ', UPLOAD_ALLOWED_EXT) . ').';
        }

        // 2) Kiem tra dung luong
        if (($file['size'] ?? 0) > UPLOAD_MAX_SIZE) {
            $errors[] = 'Dung lượng vượt quá ' . (int) (UPLOAD_MAX_SIZE /
1024 / 1024) . ' MB.';
        }

        // 3) Kiem tra LOAI THAT cua tep bang finfo - KHONG tin Content-
Type trinh duyet gui len,
        //    vi day la gia tri nguoi dung co the tu sua truoc khi gui
request.
        $finfo = new finfo(FILEINFO_MIME_TYPE);
        $realMime = $finfo->file($file['tmp_name']);
        $allowedMime = ['image/jpeg', 'image/png', 'image/webp'];
        if (!in_array($realMime, $allowedMime, true)) {
            $errors[] = 'Tệp không phải ảnh hợp lệ (phát hiện loại thật: '
. $realMime . ', ví dụ tệp .php đổi đuôi thành .jpg sẽ bị chặn tại đây).';
        }

        // 4) Kiem tra tep doc duoc nhu mot anh that va lay kich thuoc
        $dimensions = @getimagesize($file['tmp_name']);
        if ($dimensions === false) {
            $errors[] = 'Không đọc được ảnh, tệp có thể bị hỏng hoặc không
phải ảnh.';
        } else {
            [$width, $height] = $dimensions;
            $shortSide = min($width, $height);
            $longSide = max($width, $height);

            if ($shortSide < UPLOAD_MIN_SIDE) {
                $errors[] = "Ảnh quá nhỏ (cạnh ngắn {$shortSide}px, yêu cầu
tối thiểu " . UPLOAD_MIN_SIDE . "px).";
            }
            if ($longSide > UPLOAD_MAX_SIDE) {
                $errors[] = "Ảnh quá lớn (cạnh dài {$longSide}px, vượt tối
đa " . UPLOAD_MAX_SIDE . "px).";
            }
        }

        return $errors;
    }

    /**
     * Tao lai anh bang GD (KHONG luu nguyen tep goc) va luu ban chinh +
ban thu nho.
     * Tra ve ['file_name' => ..., 'original_name' => ...] de Controller
ghi vao CSDL.
     *
     * @throws RuntimeException neu khong doc duoc du lieu anh
     */
    public static function processAndSave(array $file): array
```

```
    {
        $raw = file_get_contents($file['tmp_name']);
        $source = $raw === false ? false : @imagecreatefromstring($raw);

        if ($source === false) {
            throw new RuntimeException('Khong tao duoc tai nguyen anh tu
tep tai len.');
        }

        $srcWidth = imagesx($source);
        $srcHeight = imagesy($source);

        // Ten ngau nhien - KHONG dung ten goc nguoi dung tai len
        $fileName = uniqid('prod_', true) . '.jpg';

        self::saveResized($source, $srcWidth, $srcHeight, IMAGE_MAIN_WIDTH,
self::mainPath($fileName));
        self::saveResized($source, $srcWidth, $srcHeight,
IMAGE_THUMB_WIDTH, self::thumbPath($fileName));

        imagedestroy($source);

        return [
            'file_name'     => $fileName,
            'original_name' => $file['name'],
        ];
    }

    /** Xoa ca ban chinh va ban thu nho cua MOT anh (dung khi xoa anh hoac
xoa san pham) */
    public static function deleteFiles(string $fileName): void
    {
        foreach ([self::mainPath($fileName), self::thumbPath($fileName)] as
$path) {
            if (file_exists($path) && !@unlink($path)) {
                // Khong lam hong thao tac cua nguoi dung, chi ghi log de
xu ly sau
                error_log('Khong xoa duoc file anh: ' . $path);
            }
        }
    }

    /**
     * Resize giu nguyen ty le theo chieu rong muc tieu, nen trang cho vung
     * trong suot (anh PNG), roi luu thanh JPEG chat luong 85.
     */
    private static function saveResized($source, int $srcWidth, int
$srcHeight, int $targetWidth, string $destPath): void
    {
        // Chi thu nho khi anh goc lon hon muc tieu, khong phong to anh nho
        $ratio = min(1, $targetWidth / $srcWidth);
        $destWidth = max(1, (int) round($srcWidth * $ratio));
        $destHeight = max(1, (int) round($srcHeight * $ratio));
```

```
        $dest = imagecreatetruecolor($destWidth, $destHeight);
        $white = imagecolorallocate($dest, 255, 255, 255);
        imagefill($dest, 0, 0, $white);

        imagecopyresampled($dest, $source, 0, 0, 0, 0, $destWidth,
$destHeight, $srcWidth, $srcHeight);

        imagejpeg($dest, $destPath, 85);
        imagedestroy($dest);
    }

    private static function uploadErrorMessage(int $code): string
    {
        return match ($code) {
            UPLOAD_ERR_INI_SIZE, UPLOAD_ERR_FORM_SIZE => 'Tệp vượt quá dung
lượng cho phép của máy chủ.',
            UPLOAD_ERR_PARTIAL => 'Tệp chỉ tải lên được một phần, vui lòng
thử lại.',
            UPLOAD_ERR_NO_FILE => 'Chưa chọn tệp.',
            UPLOAD_ERR_NO_TMP_DIR, UPLOAD_ERR_CANT_WRITE,
UPLOAD_ERR_EXTENSION => 'Lỗi hệ thống khi lưu tệp tải lên.',
            default => 'Lỗi tải tệp không xác định.',
        };
    }

    public static function mainPath(string $fileName): string
    {
        return __DIR__ . '/../../public/uploads/products/' . $fileName;
    }

    public static function thumbPath(string $fileName): string
    {
        return __DIR__ . '/../../public/uploads/products/thumbs/' .
$fileName;
    }
}
```

Vì sao tạo lại ảnh bằng GD thay vì lưu nguyên tệp gốc giúp loại bỏ dữ liệu lạ? Thư viện GD chỉ đọc các điểm ảnh (pixel) và vẽ lại một tệp ảnh hoàn toàn mới. Mọi thứ không phải là điểm ảnh thuần - mã khai thác lợi dụng lỗ hổng xử lý ảnh, metadata EXIF chứa script, hay toàn bộ nội dung PHP nếu tệp thực chất là mã PHP đội lốt ảnh - đều **không** được sao chép sang tệp mới, vì GD không biết và không quan tâm đến các vùng dữ liệu đó.

Bước 3: Viết Model Category

Tệp: app/models/Category.php

```
<?php
// app/models/Category.php

class Category extends Model
{
    protected static string $table = 'categories';
```

```
    public static function findBySlug(string $slug): ?array
    {
        $stmt = static::db()->prepare('SELECT * FROM categories WHERE slug
= :slug LIMIT 1');
        $stmt->execute(['slug' => $slug]);
        $row = $stmt->fetch();
        return $row === false ? null : $row;
    }

    public static function countProducts(int $categoryId): int
    {
        $stmt = static::db()->prepare('SELECT COUNT(*) FROM products WHERE
category_id = :id');
        $stmt->execute(['id' => $categoryId]);
        return (int) $stmt->fetchColumn();
    }

    /** Tao slug khong dau, chu thuong, cach nhau bang dau gach ngang */
    public static function slugify(string $name): string
    {
        $slug = mb_strtolower(trim($name), 'UTF-8');

        $map = [

'à'=>'a','á'=>'a','ạ'=>'a','ả'=>'a','ã'=>'a','â'=>'a','ầ'=>'a','ấ'=>'a','ậ'
=>'a','ẩ'=>'a','ẫ'=>'a',
            'ă'=>'a','ằ'=>'a','ắ'=>'a','ặ'=>'a','ẳ'=>'a','ẵ'=>'a',

'è'=>'e','é'=>'e','ẹ'=>'e','ẻ'=>'e','ẽ'=>'e','ê'=>'e','ề'=>'e','ế'=>'e','ệ'
=>'e','ể'=>'e','ễ'=>'e',
            'ì'=>'i','í'=>'i','ị'=>'i','ỉ'=>'i','ĩ'=>'i',

'ò'=>'o','ó'=>'o','ọ'=>'o','ỏ'=>'o','õ'=>'o','ô'=>'o','ồ'=>'o','ố'=>'o','ộ'
=>'o','ổ'=>'o','ỗ'=>'o',
            'ơ'=>'o','ờ'=>'o','ớ'=>'o','ợ'=>'o','ở'=>'o','ỡ'=>'o',

'ù'=>'u','ú'=>'u','ụ'=>'u','ủ'=>'u','ũ'=>'u','ư'=>'u','ừ'=>'u','ứ'=>'u','ự'
=>'u','ử'=>'u','ữ'=>'u',
            'ỳ'=>'y','ý'=>'y','ỵ'=>'y','ỷ'=>'y','ỹ'=>'y',
            'đ'=>'d',
        ];
        $slug = strtr($slug, $map);
        $slug = preg_replace('/[^a-z0-9]+/', '-', $slug);
        return trim($slug, '-');
    }
}
```

Bước 4: Viết Model `Product`

Tệp: `app/models/Product.php`

```php
<?php
// app/models/Product.php

class Product extends Model
{
    protected static string $table = 'products';

    /** Kiem tra SKU da ton tai chua, loai tru 1 id khi dang sua san pham
*/
    public static function skuExists(string $sku, ?int $excludeId = null):
bool
    {
        $sql = 'SELECT COUNT(*) FROM products WHERE sku = :sku';
        $params = ['sku' => $sku];

        if ($excludeId !== null) {
            $sql .= ' AND id != :id';
            $params['id'] = $excludeId;
        }

        $stmt = static::db()->prepare($sql);
        $stmt->execute($params);
        return ((int) $stmt->fetchColumn()) > 0;
    }
}
```

Bước 5: Viết Model `ProductImage` - toàn bộ nghiệp vụ ảnh sản phẩm

Đây là lớp quan trọng nhất buổi học: tập trung **toàn bộ** quy tắc nghiệp vụ về ảnh vào một nơi duy nhất để `AdminProductImageController` chỉ việc gọi hàm, không tự viết SQL rải rác.

Tệp: `app/models/ProductImage.php`

```php
<?php
// app/models/ProductImage.php
// Tap trung TOAN BO nghiep vu anh san pham: thu tu hien thi, anh dai dien
// duy nhat, xoa dung trinh tu, chong thao tac cheo san pham.

class ProductImage extends Model
{
    protected static string $table = 'product_images';

    /** Anh dai dien luon dung dau, sau do theo sort_order */
    public static function forProduct(int $productId): array
    {
        $stmt = static::db()->prepare(
            'SELECT * FROM product_images
             WHERE product_id = :pid
             ORDER BY is_primary DESC, sort_order ASC, id ASC'
        );
        $stmt->execute(['pid' => $productId]);
        return $stmt->fetchAll();
    }
```

```
    public static function countForProduct(int $productId): int
    {
        $stmt = static::db()->prepare('SELECT COUNT(*) FROM product_images
WHERE product_id = :pid');
        $stmt->execute(['pid' => $productId]);
        return (int) $stmt->fetchColumn();
    }

    public static function nextSortOrder(int $productId): int
    {
        $stmt = static::db()->prepare(
            'SELECT COALESCE(MAX(sort_order), -1) + 1 FROM product_images
WHERE product_id = :pid'
        );
        $stmt->execute(['pid' => $productId]);
        return (int) $stmt->fetchColumn();
    }

    /**
     * Dat anh $imageId lam dai dien cua $productId.
     * Dung transaction de dam bao KHONG BAO GIO xay ra tinh trang
     * 0 hoac 2 anh dai dien cung luc.
     */
    public static function setPrimary(int $imageId, int $productId): void
    {
        $db = static::db();
        $db->beginTransaction();
        try {
            // XAC NHAN anh nay THUOC DUNG san pham truoc khi doi bat cu
gi.
            // Neu thieu buoc nay: khi $imageId thuoc san pham khac, dong
UPDATE o duoi
            // van se xoa het is_primary cua san pham hien tai (buoc 1)
nhung khong anh
            // nao duoc dat lai lam dai dien (buoc 2 khop 0 dong) -> san
pham mat trang
            // ca dai dien oan uong. Kiem tra truoc giup thao tac that su
la "khong lam gi"
            // khi image_id khong thuoc product_id duoc truyen vao.
            $check = $db->prepare('SELECT COUNT(*) FROM product_images
WHERE id = :id AND product_id = :pid');
            $check->execute(['id' => $imageId, 'pid' => $productId]);
            if ((int) $check->fetchColumn() === 0) {
                $db->rollBack();
                return;
            }

            $db->prepare('UPDATE product_images SET is_primary = 0 WHERE
product_id = :pid')
               ->execute(['pid' => $productId]);

            $db->prepare('UPDATE product_images SET is_primary = 1 WHERE id
```

```
= :id AND product_id = :pid')
                ->execute(['id' => $imageId, 'pid' => $productId]);

            $db->commit();
        } catch (Throwable $e) {
            $db->rollBack();
            throw $e;
        }
    }

    /**
     * Xoa MOT anh: xoa ban ghi CSDL truoc, chi xoa tep vat ly SAU KHI
     * ban ghi da xoa thanh cong. Neu la anh dai dien thi tu dong chon
     * anh co sort_order nho nhat con lai lam dai dien moi.
     */
    public static function deleteImage(int $imageId, int $productId): void
    {
        $db = static::db();

        $stmt = $db->prepare('SELECT * FROM product_images WHERE id = :id
AND product_id = :pid LIMIT 1');
        $stmt->execute(['id' => $imageId, 'pid' => $productId]);
        $image = $stmt->fetch();

        if ($image === false) {
            // Anh khong ton tai HOAC khong thuoc san pham nay -> khong lam
gi,
            // day chinh la co che chan "doi ma anh de tac dong anh san
pham khac"
            return;
        }

        $db->beginTransaction();
        try {
            $db->prepare('DELETE FROM product_images WHERE id = :id')-
>execute(['id' => $imageId]);

            if ((int) $image['is_primary'] === 1) {
                $nextId = $db->prepare(
                    'SELECT id FROM product_images WHERE product_id = :pid
ORDER BY sort_order ASC, id ASC LIMIT 1'
                );
                $nextId->execute(['pid' => $productId]);
                $nextImageId = $nextId->fetchColumn();

                if ($nextImageId) {
                    $db->prepare('UPDATE product_images SET is_primary = 1
WHERE id = :id')
                        ->execute(['id' => $nextImageId]);
                }
            }

            $db->commit();
        } catch (Throwable $e) {
```

```
            $db->rollBack();
            throw $e;
        }

        // Chi den day - SAU KHI transaction da commit thanh cong - moi
dong den tep vat ly
        ImageService::deleteFiles($image['file_name']);
    }

    /** Dung khi xoa het mot san pham: xoa toan bo anh (tep + ban ghi) cua
no */
    public static function deleteAllForProduct(int $productId): void
    {
        $images = self::forProduct($productId);
        foreach ($images as $image) {
            ImageService::deleteFiles($image['file_name']);
        }

        static::db()->prepare('DELETE FROM product_images WHERE product_id
= :pid')
                    ->execute(['pid' => $productId]);
    }

    public static function updateAlt(int $imageId, int $productId, string
$altText): void
    {
        static::db()->prepare(
            'UPDATE product_images SET alt_text = :alt WHERE id = :id AND
product_id = :pid'
        )->execute(['alt' => $altText, 'id' => $imageId, 'pid' =>
$productId]);
    }

    /** Doi cho thu tu voi anh lien ke (khong tinh anh dai dien - anh dai
dien luon dung dau) */
    public static function swapOrder(int $imageId, int $productId, string
$direction): void
    {
        $images = self::forProduct($productId);
        $ordered = array_values(array_filter($images, fn($i) => (int)
$i['is_primary'] === 0));

        $index = null;
        foreach ($ordered as $i => $img) {
            if ((int) $img['id'] === $imageId) {
                $index = $i;
                break;
            }
        }
        if ($index === null) {
            return;
        }

        $swapWith = $direction === 'up' ? $index - 1 : $index + 1;
```

```
        if ($swapWith < 0 || $swapWith >= count($ordered)) {
            return; // da o dau hoac cuoi danh sach
        }

        $a = $ordered[$index];
        $b = $ordered[$swapWith];

        $db = static::db();
        $db->beginTransaction();
        try {
            $db->prepare('UPDATE product_images SET sort_order = :s WHERE
id = :id')
               ->execute(['s' => $b['sort_order'], 'id' => $a['id']]);
            $db->prepare('UPDATE product_images SET sort_order = :s WHERE
id = :id')
               ->execute(['s' => $a['sort_order'], 'id' => $b['id']]);
            $db->commit();
        } catch (Throwable $e) {
            $db->rollBack();
            throw $e;
        }
    }
}
```

Vì sao mọi câu lệnh đều có thêm AND `product_id = :pid`? Đây chính là cơ chế chặn yêu cầu bảo mật "mọi thao tác trên một ảnh phải kiểm tra ảnh đó thuộc đúng sản phẩm đang chỉnh sửa". Nếu ai đó cố tình sửa `image_id` trong form để trỏ sang ảnh của sản phẩm khác, câu lệnh UPDATE/DELETE sẽ khớp **0 dòng** (vì `product_id` không trùng) - thao tác coi như không xảy ra, không cần viết thêm `if` kiểm tra quyền sở hữu ở tầng Controller.

Riêng `setPrimary()` cần thêm một bước SELECT xác nhận quyền sở hữu trước khi làm gì cả - khác với `deleteImage()`/`updateAlt()` chỉ có đúng một câu lệnh ghi dữ liệu nên tự nhiên đã an toàn, `setPrimary()` gồm **hai** câu lệnh UPDATE nối tiếp (xoá cờ đại diện cũ, rồi gán cờ đại diện mới). Nếu bỏ qua bước xác nhận, khi `image_id` không thuộc `productId` truyền vào, câu lệnh đầu vẫn xoá sạch cờ đại diện hiện có, còn câu lệnh sau khớp 0 dòng - kết quả là sản phẩm mất trắng ảnh đại diện dù "thao tác coi như không hợp lệ". Đây là một ví dụ thực tế cho thấy một thao tác gồm nhiều bước ghi dữ liệu luôn cần được kiểm thử kỹ, không chỉ suy luận bằng mắt.

Bước 6: Viết `AdminCategoryController` và view

Tệp: `app/controllers/admin/AdminCategoryController.php`

```
<?php
// app/controllers/admin/AdminCategoryController.php

class AdminCategoryController extends AdminController
{
    public function index(): void
    {
        $sql = "SELECT c.*, COUNT(p.id) AS product_count
                FROM categories c
                LEFT JOIN products p ON p.category_id = c.id
                GROUP BY c.id
```

```
                ORDER BY c.name ASC";
        $categories = Database::getInstance()->query($sql)->fetchAll();

        $this->view('admin/category/index', ['pageTitle' => 'Quản lý danh
mục', 'categories' => $categories]);
    }

    public function add(): void
    {
        if ($_SERVER['REQUEST_METHOD'] === 'POST') {
            $this->store();
            return;
        }
        $this->view('admin/category/form', ['pageTitle' => 'Thêm danh mục',
'category' => null]);
    }

    protected function store(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $name = trim($_POST['name'] ?? '');
        if ($name === '') {
            flash('error', 'Tên danh mục không được để trống.');
            $this->redirect('admin/category/add');
            return;
        }

        Category::insert([
            'name'   => $name,
            'slug'   => Category::slugify($name),
            'status' => isset($_POST['status']) ? 'active' : 'inactive',
        ]);

        flash('success', 'Đã thêm danh mục.');
        $this->redirect('admin/category');
    }

    public function edit($id): void
    {
        $category = Category::find((int) $id);
        if (!$category) {
            flash('error', 'Danh mục không tồn tại.');
            $this->redirect('admin/category');
            return;
        }

        if ($_SERVER['REQUEST_METHOD'] === 'POST') {
            $this->updateCategory((int) $id);
            return;
        }

        $this->view('admin/category/form', ['pageTitle' => 'Sửa danh mục',
'category' => $category]);
```

```
    }

    protected function updateCategory(int $id): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $name = trim($_POST['name'] ?? '');
        if ($name === '') {
            flash('error', 'Tên danh mục không được để trống.');
            $this->redirect('admin/category/edit/' . $id);
            return;
        }

        Category::update($id, [
            'name'   => $name,
            'slug'   => Category::slugify($name),
            'status' => isset($_POST['status']) ? 'active' : 'inactive',
        ]);

        flash('success', 'Đã cập nhật danh mục.');
        $this->redirect('admin/category');
    }

    public function delete(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');
        $id = (int) ($_POST['id'] ?? 0);

        if (Category::countProducts($id) > 0) {
            flash('error', 'Không thể xoá danh mục đang có sản phẩm. Hãy
chuyển sản phẩm sang danh mục khác hoặc ẩn danh mục này.');
            $this->redirect('admin/category');
            return;
        }

        Category::delete($id);
        flash('success', 'Đã xoá danh mục.');
        $this->redirect('admin/category');
    }
}
```

Tệp: app/views/admin/category/index.php

```
<div class="d-flex justify-content-end mb-3">
    <a href="<?= e(base_url('admin/category/add')) ?>" class="btn btn-
primary">+ Thêm danh mục</a>
</div>

<div class="table-responsive">
    <table class="table table-bordered bg-white align-middle">
        <thead class="table-light">
        <tr>
            <th>#</th><th>Tên danh mục</th><th>Slug</th><th>Số sản
phẩm</th><th>Trạng thái</th>
```

```
            <th style="width: 170px;">Thao tác</th>
        </tr>
        </thead>
        <tbody>
        <?php foreach ($categories as $c): ?>
            <tr>
                <td><?= (int) $c['id'] ?></td>
                <td><?= e($c['name']) ?></td>
                <td><code><?= e($c['slug']) ?></code></td>
                <td><?= (int) $c['product_count'] ?></td>
                <td>
                    <?php if ($c['status'] === 'active'): ?>
                        <span class="badge bg-success">Hiển thị</span>
                    <?php else: ?>
                        <span class="badge bg-secondary">Đang ẩn</span>
                    <?php endif; ?>
                </td>
                <td>
                    <a href="<?= e(base_url('admin/category/edit/' .
$c['id'])) ?>" class="btn btn-sm btn-outline-primary">Sửa</a>
                    <form method="POST" action="<?=
e(base_url('admin/category/delete')) ?>" class="d-inline"
                          onsubmit="return confirm('Xoá danh mục này?');">
                        <?= csrf_field() ?>
                        <input type="hidden" name="id" value="<?= (int)
$c['id'] ?>">
                        <button class="btn btn-sm btn-outline-danger"
                                <?= $c['product_count'] > 0 ? 'disabled
title="Còn sản phẩm, không thể xoá"' : '' ?>>
                            Xoá
                        </button>
                    </form>
                </td>
            </tr>
        <?php endforeach; ?>
        </tbody>
    </table>
</div>
```

Tệp: app/views/admin/category/form.php

```
<?php $isEdit = $category !== null; ?>
<form method="POST"
      action="<?= e($isEdit ? base_url('admin/category/edit/' .
$category['id']) : base_url('admin/category/add')) ?>"
      class="col-md-6">
    <?= csrf_field() ?>
    <div class="mb-3">
        <label class="form-label">Tên danh mục</label>
        <input type="text" name="name" class="form-control" value="<?=
e($category['name'] ?? '') ?>" required>
    </div>
    <div class="form-check mb-3">
```

```
        <input type="checkbox" name="status" class="form-check-input"
id="statusCheck"
               <?= (!$isEdit || $category['status'] === 'active') ?
'checked' : '' ?>>
        <label class="form-check-label" for="statusCheck">Hiển thị danh
mục</label>
    </div>
    <button type="submit" class="btn btn-primary"><?= $isEdit ? 'Lưu thay
đổi' : 'Thêm danh mục' ?></button>
    <a href="<?= e(base_url('admin/category')) ?>" class="btn btn-outline-
secondary">Huỷ</a>
</form>
```

Bước 7: Viết `AdminProductController` - CRUD thông tin sản phẩm

Tệp: app/controllers/admin/AdminProductController.php

```
<?php
// app/controllers/admin/AdminProductController.php

class AdminProductController extends AdminController
{
    public function index(): void
    {
        $sql = "SELECT p.*, c.name AS category_name,
                       pi.file_name AS image,
                       (SELECT COUNT(*) FROM product_images WHERE
product_id = p.id) AS image_count
                FROM products p
                JOIN categories c ON c.id = p.category_id
                LEFT JOIN product_images pi ON pi.product_id = p.id AND
pi.is_primary = 1
                ORDER BY p.created_at DESC";
        $products = Database::getInstance()->query($sql)->fetchAll();

        $this->view('admin/product/index', ['pageTitle' => 'Quản lý sản
phẩm', 'products' => $products]);
    }

    public function add(): void
    {
        if ($_SERVER['REQUEST_METHOD'] === 'POST') {
            $this->store();
            return;
        }

        $this->view('admin/product/form', [
            'pageTitle'  => 'Thêm sản phẩm',
            'categories' => Category::all('name ASC'),
            'product'    => null,
        ]);
    }
```

```php
    protected function store(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        [$data, $errors] = $this->validateProduct($_POST, null);

        if (!empty($errors)) {
            flash('error', implode('<br>', array_map('e', $errors)));
            $this->redirect('admin/product/add');
            return;
        }

        $productId = Product::insert($data);

        flash('success', 'Đã thêm sản phẩm. Hãy tải ảnh cho sản phẩm ở phần bên dưới.');
        $this->redirect('admin/product/edit/' . $productId);
    }

    public function edit($id): void
    {
        $product = Product::find((int) $id);
        if (!$product) {
            flash('error', 'Sản phẩm không tồn tại.');
            $this->redirect('admin/product');
            return;
        }

        if ($_SERVER['REQUEST_METHOD'] === 'POST') {
            $this->updateProduct((int) $id);
            return;
        }

        $this->view('admin/product/form', [
            'pageTitle'  => 'Sửa sản phẩm',
            'categories' => Category::all('name ASC'),
            'product'    => $product,
            'images'     => ProductImage::forProduct((int) $id),
        ]);
    }

    protected function updateProduct(int $id): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        [$data, $errors] = $this->validateProduct($_POST, $id);

        if (!empty($errors)) {
            flash('error', implode('<br>', array_map('e', $errors)));
            $this->redirect('admin/product/edit/' . $id);
            return;
        }

        // Chi cap nhat thong tin san pham - KHONG dong den anh (anh quan
```

```
ly rieng,
        // xem AdminProductImageController) => sua thong tin KHONG lam mat
anh.
        Product::update($id, $data);

        flash('success', 'Đã cập nhật sản phẩm.');
        $this->redirect('admin/product/edit/' . $id);
    }

    public function delete(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');
        $id = (int) ($_POST['id'] ?? 0);

        // Xoa toan bo anh (tep + ban ghi) TRUOC khi xoa san pham
        ProductImage::deleteAllForProduct($id);
        Product::delete($id);

        flash('success', 'Đã xoá sản phẩm và toàn bộ ảnh liên quan.');
        $this->redirect('admin/product');
    }

    /** @return array{0: array, 1: string[]} [du_lieu_de_luu,
danh_sach_loi] */
    protected function validateProduct(array $input, ?int $excludeId):
array
    {
        $errors = [];

        $name = trim($input['name'] ?? '');
        $sku = trim($input['sku'] ?? '');
        $categoryId = (int) ($input['category_id'] ?? 0);
        $price = (float) ($input['price'] ?? 0);
        $stock = (int) ($input['stock'] ?? 0);

        if ($name === '') {
            $errors[] = 'Tên sản phẩm không được để trống.';
        }
        if ($sku === '') {
            $errors[] = 'SKU không được để trống.';
        } elseif (Product::skuExists($sku, $excludeId)) {
            $errors[] = 'SKU đã tồn tại, vui lòng chọn mã khác.';
        }
        if ($categoryId <= 0 || !Category::find($categoryId)) {
            $errors[] = 'Vui lòng chọn danh mục hợp lệ.';
        }
        if ($price <= 0) {
            $errors[] = 'Giá phải lớn hơn 0.';
        }
        if ($stock < 0) {
            $errors[] = 'Tồn kho không được là số âm.';
        }

        $data = [
```

```
            'category_id' => $categoryId,
            'sku'         => $sku,
            'name'        => $name,
            'brand'       => trim($input['brand'] ?? ''),
            'description' => trim($input['description'] ?? ''),
            'price'       => $price,
            'stock'       => $stock,
            'is_featured' => isset($input['is_featured']) ? 1 : 0,
            'status'      => in_array($input['status'] ?? '', ['active',
'inactive'], true) ? $input['status'] : 'active',
        ];

        return [$data, $errors];
    }
}
```

Tệp: app/views/admin/product/index.php

```
<div class="d-flex justify-content-end mb-3">
    <a href="<?= e(base_url('admin/product/add')) ?>" class="btn btn-
primary">+ Thêm sản phẩm</a>
</div>

<div class="table-responsive">
    <table class="table table-bordered bg-white align-middle">
        <thead class="table-light">
        <tr>
            <th>Ảnh</th><th>SKU</th><th>Tên sản phẩm</th><th>Danh mục</th>
            <th>Giá</th><th>Tồn</th><th>Số ảnh</th><th>Trạng thái</th>
            <th style="width: 140px;">Thao tác</th>
        </tr>
        </thead>
        <tbody>
        <?php foreach ($products as $p): ?>
            <tr>
                <td>
                    <img src="<?= e(product_image_url($p['image'],
'thumb')) ?>"
                         width="48" height="48" style="object-fit: cover;"
alt="">
                </td>
                <td><?= e($p['sku']) ?></td>
                <td><?= e($p['name']) ?></td>
                <td><?= e($p['category_name']) ?></td>
                <td><?= format_vnd($p['price']) ?></td>
                <td><?= (int) $p['stock'] ?></td>
                <td><?= (int) $p['image_count'] ?>/<?= UPLOAD_MAX_IMAGES
?></td>
                <td>
                    <?php if ($p['status'] === 'active'): ?>
                        <span class="badge bg-success">Đang bán</span>
                    <?php else: ?>
                        <span class="badge bg-secondary">Ngừng bán</span>
```

```
                    <?php endif; ?>
                </td>
                <td>
                    <a href="<?= e(base_url('admin/product/edit/' .
$p['id'])) ?>" class="btn btn-sm btn-outline-primary">Sửa</a>
                    <form method="POST" action="<?=
e(base_url('admin/product/delete')) ?>" class="d-inline"
                          onsubmit="return confirm('Xoá sản phẩm này và
toàn bộ ảnh của nó?');">
                        <?= csrf_field() ?>
                        <input type="hidden" name="id" value="<?= (int)
$p['id'] ?>">
                        <button class="btn btn-sm btn-outline-
danger">Xoá</button>
                    </form>
                </td>
            </tr>
        <?php endforeach; ?>
        </tbody>
    </table>
</div>
```

Bước 8: Viết `AdminProductImageController` - xử lý thao tác ảnh

Tệp: app/controllers/admin/AdminProductImageController.php

```
<?php
// app/controllers/admin/AdminProductImageController.php
// Nhan request AJAX/POST tu khu vuc "Anh san pham" trong trang sua san
pham.

class AdminProductImageController extends AdminController
{
    /** Tai len nhieu anh cung luc - moi anh xu ly doc lap, tra ket qua
rieng cho tung anh */
    public function upload(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $productId = (int) ($_POST['product_id'] ?? 0);
        $product = Product::find($productId);

        if (!$product) {
            flash('error', 'Sản phẩm không tồn tại.');
            $this->redirect('admin/product');
            return;
        }

        $currentCount = ProductImage::countForProduct($productId);
        $files = $this->normalizeFiles($_FILES['images'] ?? []);

        if (empty($files)) {
            flash('error', 'Vui lòng chọn ít nhất một tệp ảnh.');
```

```
            $this->redirect('admin/product/edit/' . $productId);
            return;
        }

        $results = [];

        foreach ($files as $file) {
            if ($currentCount >= UPLOAD_MAX_IMAGES) {
                $results[] = e($file['name']) . ': đã đạt tối đa ' .
UPLOAD_MAX_IMAGES . ' ảnh, bỏ qua.';
                continue;
            }

            $errors = ImageService::validate($file);
            if (!empty($errors)) {
                $results[] = e($file['name']) . ': ' . e(implode('; ',
$errors));
                continue;
            }

            try {
                $saved = ImageService::processAndSave($file);
            } catch (Throwable $e) {
                error_log('ImageService::processAndSave loi: ' . $e-
>getMessage());
                $results[] = e($file['name']) . ': lỗi xử lý ảnh phía máy
chủ.';
                continue;
            }

            $isFirstImage = $currentCount === 0;

            ProductImage::insert([
                'product_id'    => $productId,
                'file_name'     => $saved['file_name'],
                'original_name' => $saved['original_name'],
                'alt_text'      => $product['name'],
                'is_primary'    => $isFirstImage ? 1 : 0,
                'sort_order'    => ProductImage::nextSortOrder($productId),
            ]);

            $currentCount++;
            $results[] = e($file['name']) . ': tải lên thành công.';
        }

        // Luu y: moi dong trong $results da duoc e() tu truoc, nen khong
e() lai o day
        flash('success', implode('<br>', $results));
        $this->redirect('admin/product/edit/' . $productId);
    }

    public function setPrimary(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');
```

```php
        $productId = (int) ($_POST['product_id'] ?? 0);
        $imageId = (int) ($_POST['image_id'] ?? 0);

        ProductImage::setPrimary($imageId, $productId);

        flash('success', 'Đã đặt làm ảnh đại diện.');
        $this->redirect('admin/product/edit/' . $productId);
    }

    public function delete(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $productId = (int) ($_POST['product_id'] ?? 0);
        $imageId = (int) ($_POST['image_id'] ?? 0);

        ProductImage::deleteImage($imageId, $productId);

        flash('success', 'Đã xoá ảnh.');
        $this->redirect('admin/product/edit/' . $productId);
    }

    public function reorder(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $productId = (int) ($_POST['product_id'] ?? 0);
        $imageId = (int) ($_POST['image_id'] ?? 0);
        $direction = ($_POST['direction'] ?? '') === 'down' ? 'down' :
'up';

        ProductImage::swapOrder($imageId, $productId, $direction);

        $this->redirect('admin/product/edit/' . $productId);
    }

    public function updateAlt(): void
    {
        verify_csrf($_POST['csrf_token'] ?? '');

        $productId = (int) ($_POST['product_id'] ?? 0);
        $imageId = (int) ($_POST['image_id'] ?? 0);
        $altText = trim($_POST['alt_text'] ?? '');

        ProductImage::updateAlt($imageId, $productId, $altText);

        flash('success', 'Đã cập nhật văn bản thay thế.');
        $this->redirect('admin/product/edit/' . $productId);
    }

    /** Chuan hoa $_FILES['images'] (mang nhieu tep) thanh mang cac tep
rieng le, de lap de */
    protected function normalizeFiles(array $filesArray): array
    {
```

```
        if (empty($filesArray['name'])) {
            return [];
        }

        $normalized = [];
        $count = count($filesArray['name']);

        for ($i = 0; $i < $count; $i++) {
            if (($filesArray['error'][$i] ?? UPLOAD_ERR_NO_FILE) ===
UPLOAD_ERR_NO_FILE) {
                continue;
            }
            $normalized[] = [
                'name'     => $filesArray['name'][$i],
                'type'     => $filesArray['type'][$i],
                'tmp_name' => $filesArray['tmp_name'][$i],
                'error'    => $filesArray['error'][$i],
                'size'     => $filesArray['size'][$i],
            ];
        }

        return $normalized;
    }
}
```

> **Vì sao kiểm tra `if (!$product)` ngay từ đầu `upload()`?** Vì `product_id` đến từ một trường `hidden` trong form - hoàn toàn có thể bị sửa bằng DevTools. Luôn coi mọi dữ liệu từ `$_POST` là không đáng tin cho đến khi được kiểm tra lại với CSDL.

Bước 9: Hoàn thiện view `admin/product/form.php` - thông tin + khu vực ảnh

Đây là view dùng chung cho cả **thêm mới** và **sửa** sản phẩm; khu vực quản lý ảnh chỉ hiển thị khi đang **sửa** (vì cần có `product_id` để gắn ảnh vào).

Tệp: `app/views/admin/product/form.php`

```
<?php $isEdit = $product !== null; ?>

<form method="POST"
      action="<?= e($isEdit ? base_url('admin/product/edit/' .
$product['id']) : base_url('admin/product/add')) ?>"
      class="row g-3 mb-5">
    <?= csrf_field() ?>

    <div class="col-md-4">
        <label class="form-label">SKU</label>
        <input type="text" name="sku" class="form-control" value="<?=
e($product['sku'] ?? '') ?>" required>
    </div>
    <div class="col-md-8">
        <label class="form-label">Tên sản phẩm</label>
        <input type="text" name="name" class="form-control" value="<?=
e($product['name'] ?? '') ?>" required>
```

```
    </div>

    <div class="col-md-6">
        <label class="form-label">Danh mục</label>
        <select name="category_id" class="form-select" required>
            <option value="">-- Chọn danh mục --</option>
            <?php foreach ($categories as $c): ?>
                <option value="<?= (int) $c['id'] ?>"
                    <?= isset($product['category_id']) && (int)
$product['category_id'] === (int) $c['id'] ? 'selected' : '' ?>>
                    <?= e($c['name']) ?>
                </option>
            <?php endforeach; ?>
        </select>
    </div>
    <div class="col-md-6">
        <label class="form-label">Thương hiệu</label>
        <input type="text" name="brand" class="form-control" value="<?=
e($product['brand'] ?? '') ?>">
    </div>

    <div class="col-12">
        <label class="form-label">Mô tả</label>
        <textarea name="description" class="form-control" rows="4"><?=
e($product['description'] ?? '') ?></textarea>
    </div>

    <div class="col-md-4">
        <label class="form-label">Giá bán (đ)</label>
        <input type="number" name="price" class="form-control" min="1"
step="1000"
               value="<?= e((string) ($product['price'] ?? '')) ?>"
required>
    </div>
    <div class="col-md-4">
        <label class="form-label">Tồn kho</label>
        <input type="number" name="stock" class="form-control" min="0"
               value="<?= e((string) ($product['stock'] ?? 0)) ?>"
required>
    </div>
    <div class="col-md-4">
        <label class="form-label">Trạng thái kinh doanh</label>
        <select name="status" class="form-select">
            <option value="active" <?= ($product['status'] ?? 'active') ===
'active' ? 'selected' : '' ?>>Đang bán</option>
            <option value="inactive" <?= ($product['status'] ?? '') ===
'inactive' ? 'selected' : '' ?>>Ngừng bán</option>
        </select>
    </div>

    <div class="col-12 form-check">
        <input type="checkbox" name="is_featured" class="form-check-input"
id="featuredCheck"
```

```
                <?= !empty($product['is_featured']) ? 'checked' : '' ?>>
            <label class="form-check-label" for="featuredCheck">Sản phẩm nổi
bật (hiển thị ở trang chủ)</label>
        </div>

        <div class="col-12">
            <button type="submit" class="btn btn-primary">
                <?= $isEdit ? 'Lưu thay đổi' : 'Thêm sản phẩm, tiếp tục thêm
ảnh' ?>
            </button>
            <a href="<?= e(base_url('admin/product')) ?>" class="btn btn-
outline-secondary">Huỷ</a>
        </div>
    </form>

    <?php if ($isEdit): ?>
        <hr>
        <h2 class="h5 mb-3">
            Ảnh sản phẩm
            <span class="badge bg-secondary"><?= count($images) ?>/<?=
UPLOAD_MAX_IMAGES ?></span>
        </h2>

        <div class="row row-cols-2 row-cols-md-4 g-3 mb-4">
            <?php foreach ($images as $img): ?>
                <div class="col">
                    <div class="card h-100 <?= $img['is_primary'] ? 'border-
primary border-2' : '' ?>">
                        <img src="<?= e(product_image_url($img['file_name'],
'thumb')) ?>"
                             class="card-img-top" style="aspect-ratio: 1/1;
object-fit: cover;"
                             alt="<?= e($img['alt_text'] ?? '') ?>">
                        <div class="card-body p-2">
                            <?php if ($img['is_primary']): ?>
                                <span class="badge bg-primary mb-2 d-block">Ảnh
đại diện</span>
                            <?php else: ?>
                                <form method="POST" action="<?=
e(base_url('admin/productImage/setPrimary')) ?>" class="mb-2">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="product_id"
value="<?= (int) $product['id'] ?>">
                                    <input type="hidden" name="image_id"
value="<?= (int) $img['id'] ?>">
                                    <button class="btn btn-sm btn-outline-
primary w-100">Đặt làm đại diện</button>
                                </form>
                            <?php endif; ?>

                            <form method="POST" action="<?=
e(base_url('admin/productImage/updateAlt')) ?>" class="mb-2">
                                <?= csrf_field() ?>
```

```
                            <input type="hidden" name="product_id"
value="<?= (int) $product['id'] ?>">
                            <input type="hidden" name="image_id" value="<?=
(int) $img['id'] ?>">
                            <input type="text" name="alt_text" class="form-
control form-control-sm mb-1"
                                   value="<?= e($img['alt_text'] ?? '') ?>"
placeholder="Văn bản thay thế (alt)">
                            <button class="btn btn-sm btn-outline-secondary
w-100">Lưu alt</button>
                        </form>

                        <?php if (!$img['is_primary']): ?>
                            <div class="d-flex gap-1 mb-2">
                                <form method="POST" action="<?=
e(base_url('admin/productImage/reorder')) ?>">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="product_id"
value="<?= (int) $product['id'] ?>">
                                    <input type="hidden" name="image_id"
value="<?= (int) $img['id'] ?>">
                                    <input type="hidden" name="direction"
value="up">
                                    <button class="btn btn-sm btn-outline-
dark" title="Lên trước">&uarr;</button>
                                </form>
                                <form method="POST" action="<?=
e(base_url('admin/productImage/reorder')) ?>">
                                    <?= csrf_field() ?>
                                    <input type="hidden" name="product_id"
value="<?= (int) $product['id'] ?>">
                                    <input type="hidden" name="image_id"
value="<?= (int) $img['id'] ?>">
                                    <input type="hidden" name="direction"
value="down">
                                    <button class="btn btn-sm btn-outline-
dark" title="Xuống sau">&darr;</button>
                                </form>
                            </div>
                        <?php endif; ?>

                        <form method="POST" action="<?=
e(base_url('admin/productImage/delete')) ?>"
                              onsubmit="return confirm('Xoá ảnh này?');">
                            <?= csrf_field() ?>
                            <input type="hidden" name="product_id"
value="<?= (int) $product['id'] ?>">
                            <input type="hidden" name="image_id" value="<?=
(int) $img['id'] ?>">
                            <button class="btn btn-sm btn-outline-danger w-
100">Xoá ảnh</button>
                        </form>
                    </div>
```

```
                </div>
            </div>
        <?php endforeach; ?>

        <?php if (empty($images)): ?>
            <p class="text-muted">Sản phẩm chưa có ảnh nào. Trang chủ và
danh mục sẽ hiển thị ảnh mặc định cho đến khi có ảnh.</p>
        <?php endif; ?>
    </div>

    <?php if (count($images) < UPLOAD_MAX_IMAGES): ?>
        <form method="POST" action="<?=
e(base_url('admin/productImage/upload')) ?>"
              enctype="multipart/form-data" class="col-md-8">
            <?= csrf_field() ?>
            <input type="hidden" name="product_id" value="<?= (int)
$product['id'] ?>">
            <label class="form-label">
                Thêm ảnh mới (có thể chọn nhiều tệp cùng lúc –
jpg/png/webp, tối đa 2MB mỗi ảnh)
            </label>
            <div class="input-group">
                <input type="file" name="images[]" class="form-control"
accept=".jpg,.jpeg,.png,.webp" multiple required>
                <button class="btn btn-primary">Tải lên</button>
            </div>
        </form>
    <?php else: ?>
        <p class="text-muted">Đã đạt số lượng ảnh tối đa (<?=
UPLOAD_MAX_IMAGES ?> ảnh/sản phẩm).</p>
    <?php endif; ?>
<?php endif; ?>
```

> **Lưu ý về `enctype="multipart/form-data"`:** đây là thuộc tính **bắt buộc** trên thẻ `<form>` mỗi khi form có `<input type="file">` - thiếu thuộc tính này, trình duyệt sẽ gửi tên tệp dưới dạng chữ thường thay vì nội dung nhị phân, và `$_FILES` ở phía máy chủ sẽ luôn rỗng.

5. Chạy thử và kiểm tra

1. Vào `/admin/category`, thêm 1 danh mục mới, sửa, rồi thử xoá một danh mục **đang có sản phẩm** → phải bị chặn với thông báo rõ ràng.
2. Vào `/admin/product/add`, thêm một sản phẩm mới → sau khi lưu phải chuyển thẳng đến trang sửa, đã thấy khu vực "Ảnh sản phẩm".
3. Tải lên cùng lúc 3–4 ảnh hợp lệ (dùng ảnh thật trên máy, không phải ảnh do script sinh ở Buổi 1) → tất cả xuất hiện, ảnh đầu tiên tự động là đại diện (viền xanh).
4. Bấm **Đặt làm đại diện** ở một ảnh khác → viền xanh chuyển đúng sang ảnh vừa chọn, không còn ảnh nào khác có badge đại diện.
5. Dùng nút **↑ / ↓** đổi thứ tự hai ảnh không phải đại diện → thứ tự hiển thị thay đổi đúng.
6. Xoá ảnh đang là đại diện → ảnh có `sort_order` nhỏ nhất còn lại tự động trở thành đại diện mới.

7. Xoá toàn bộ ảnh của một sản phẩm → trang chủ (Buổi 1) hiển thị lại đúng ảnh mặc định cho sản phẩm đó.
8. Mở thư mục `public/uploads/products/` và `thumbs/` trên máy, đối chiếu số lượng tệp với số bản ghi `product_images` trong CSDL — phải khớp nhau tuyệt đối sau mọi lần thêm/xoá.
9. Dùng tài khoản đã đăng ký ở Buổi 2 (vai trò `admin`), vào `/admin/product`, bấm **Thêm ảnh** cho **20 sản phẩm mẫu** đã tạo ở Buổi 1 (dùng ảnh thật của bạn) để toàn bộ 20 sản phẩm đều có ảnh thật — việc này hoàn thiện yêu cầu "toàn bộ sản phẩm mẫu đều có ảnh" của buổi học.

5.1. Bảng kiểm thử tải ảnh (tối thiểu 8 ca)

Lập bảng sau trong báo cáo nộp bài, tự điền cột **Kết quả thực tế** và **Đạt/Không đạt** sau khi tự kiểm thử trên máy của bạn:

STT	Ca kiểm thử	Dữ liệu vào	Kết quả mong đợi
1	Ảnh hợp lệ	Tệp `.jpg` 800×800px, 300KB	Tải lên thành công, có bản chính và bản thu nhỏ
2	Vượt dung lượng	Tệp `.jpg` 3.5MB	Bị từ chối, báo "Dung lượng vượt quá 2 MB"
3	Mã PHP đổi đuôi thành `.jpg`	Tệp `shell.php` đổi tên thành `shell.jpg`	Bị từ chối tại bước kiểm tra `finfo` (loại thật không phải ảnh)
4	Tệp văn bản đổi đuôi thành `.png`	Tệp `.txt` đổi tên thành `anh.png`	Bị từ chối, `getimagesize()` hoặc `finfo` phát hiện sai
5	Ảnh quá nhỏ	Ảnh `.jpg` 100×100px	Bị từ chối, báo "Ảnh quá nhỏ"
6	Ảnh vượt kích thước điểm ảnh	Ảnh `.png` 6000×4000px	Bị từ chối, báo "Ảnh quá lớn"
7	Vượt quá 8 ảnh	Sản phẩm đã có 8 ảnh, tải thêm 1 ảnh hợp lệ	Bị bỏ qua với thông báo "đã đạt tối đa"
8	Chưa đăng nhập / tài khoản `customer`	Gửi thẳng request POST đến `admin/productImage/upload`	Bị chặn bởi `Auth::requireRole()`, trả về chuyển hướng đăng nhập hoặc 403
9	Sửa `image_id` sang ảnh của sản phẩm khác	Đổi `image_id` trong form xoá/đặt đại diện sang id ảnh thuộc sản phẩm B trong lúc đang sửa sản phẩm A	Không có thay đổi nào xảy ra (0 dòng khớp điều kiện `product_id`)

6. Checklist nghiệm thu cuối buổi

- ☐ Thêm được ít nhất 5 sản phẩm mới, mỗi sản phẩm có từ 3 ảnh thật trở lên, có đúng 1 ảnh đại diện.

- ☐ Toàn bộ 20 sản phẩm mẫu ở Buổi 1 đều đã có ảnh thật (không còn dùng ảnh do script GD sinh tạm ở Buổi 1, trừ khi bạn muốn giữ lại cho nhanh - tối thiểu phải demo được chức năng trên 5 sản phẩm).
- ☐ Không có tệp nào dư thừa hoặc thiếu so với bản ghi `product_images` sau khi thêm/xoá/đổi đại diện nhiều lần.
- ☐ Không thể xoá danh mục còn sản phẩm.
- ☐ Sửa thông tin sản phẩm (tên, giá…) không làm mất hay thay đổi ảnh đã có.
- ☐ Toàn bộ 9 ca trong bảng kiểm thử tải ảnh đều đạt kết quả đúng như mong đợi.
- ☐ Thư mục `public/uploads/` không thể truy cập và thực thi một tệp `.php` đặt thử trong đó.

7. Bài tập mở rộng (tự làm thêm)

1. Xem trước ảnh (preview) ngay trên form trước khi bấm "Tải lên", dùng JavaScript (`URL.createObjectURL`), không cần gửi lên máy chủ mới xem được.
2. Kéo-thả để tải ảnh (drag & drop) và kéo-thả để sắp xếp lại thứ tự (thay cho hai nút ↑/↓).
3. Sinh thêm định dạng WebP cho bản thu nhỏ (dùng `imagewebp()`) song song với bản JPEG hiện tại, phục vụ trình duyệt hỗ trợ WebP.
4. Thêm bảng `banners` riêng để admin tự quản lý ảnh banner trang chủ thay vì ảnh tĩnh đặt sẵn trong `assets/`.

8. Nộp bài: đẩy mã nguồn lên GitHub

```
git add -A
git commit -m "Buoi 3: CRUD danh muc/san pham, ImageService, quan ly anh
san pham day du"
git push
```

Trong phần mô tả commit hoặc một tệp `BAOCAO_BUOI3.md` riêng, đính kèm bảng kiểm thử tải ảnh ở mục 5.1 đã điền đầy đủ kết quả thực tế.